

# Data quality audit

Missed CVEs, latest-version correctness, and database integrity · MongoDB `pwn2own_updater` · 2026-08-19

Snapshot of what is in Mongo today versus vendor pages (live version checkers, GitHub/npm) and NVD 2.0 keyword search. Not a full recrawl of every possible alias.

## 1. Verdict

The database is **structurally healthy** (no orphans, no duplicate IDs, versions resolve to real targets). Software latest-versions match vendor sources. The gaps are search quality and one version meaning:

- ~46+ **real CVEs never stored** because seed used long official names and no aliases (*Claude Code*, *pgvector*).
- ~17 **Chroma rows are false positives** (FFmpeg / Razer / ChromeOS “chroma”).
- **Samsung Galaxy S26 version is the global SMR bulletin**, not an S26 firmware string. The page does not mention S26.
- **Incremental NVD sync 404s** for any target that already has a 2026 CVE (*pubStartDate* without *pubEndDate*).

## 2. Inventory

| Collection             | Count | Integrity                                         |
|------------------------|-------|---------------------------------------------------|
| targets                | 11    | Unique normalized_name. No duplicates.            |
| vendor_configs         | 11    | One checker bound to each target (Oura included). |
| target_versions        | 12    | All target_ids resolve. One is_latest per target. |
| vulnerabilities        | 78    | Unique advisory_id. NVD 73, ZDI 7 (2 overlap).    |
| target_vulnerabilities | 78    | 0 orphan links. 0 unlinked vulns.                 |

Leftover empty database `p2o` has the same collection names and 0 documents. The bot `.env` points at `pwn2own_updater` only. Harmless.

Last vuln *created\_at*: **2026-08-18 04:17 UTC** (no CVE written on 2026-08-19). Version scan *last\_seen*: **2026-08-19 01:04 UTC** (08:04 UTC+7) — daily version pass ran.

## 3. Latest versions

Live lookup used the same *FirmwareLookupService* path as `/check-version`. Independent check used GitHub Releases/tags or npm latest.

| Target                  | DB / live          | Independent                           | Verdict               |
|-------------------------|--------------------|---------------------------------------|-----------------------|
| Anthropic Claude Code   | 2.1.235            | npm @anthropic-ai/claude-code 2.1.235 | OK                    |
| Chroma                  | 1.5.9              | GitHub chroma-core/chroma 1.5.9       | OK                    |
| Home Assistant Green    | 18.2               | GitHub HA OS 18.2                     | OK                    |
| LiteLLM                 | v1.97.0            | GitHub BerriAI/litellm v1.97.0        | OK                    |
| NVIDIA Dynamo           | v1.4.0             | GitHub ai-dynamo/dynamo v1.4.0        | OK                    |
| OpenAI Codex            | 0.148.0            | npm @openai/codex 0.148.0             | OK                    |
| Oracle Autonomous AI DB | 23.26.3            | same Oracle page / regex              | OK (self-consistent)  |
| Oura Ring 5             | 2.1.3              | same Oura support page / regex        | OK (self-consistent)  |
| Philips Hue Bridge Pro  | 2071401010         | same Hue release-notes page           | OK (self-consistent)  |
| Postgres pgvector       | 0.8.6              | GitHub tags v0.8.6 (HTML 429)         | OK                    |
| Samsung Galaxy S26      | Aug-2026 Release 1 | Global SMR bulletin; no “S26” on page | WRONG kind of version |

Claude Code has two version rows (2.1.234 previous, 2.1.235 latest) — expected history.

### 3.1 Samsung — wrong meaning, not a stale number

Checker regex `SMR Month-20xx Release N on security.samsungmobile.com/securityUpdate.smsb`. First match is the global “SMR Aug-2026 Release 1” paragraph. Strings S26, Galaxy S26, SM-S93, SM-S94 are **absent**. Stored value is this month’s Samsung-wide SMR label, not a Galaxy S26 firmware / One UI / AP build.

pgvector `CHANGELOG.html` returned HTTP 429 during the audit; tag v0.8.6 still matches the DB.

## 4. CVE coverage vs NVD

The tool searches **exact** keywordSearch=<target.name> only. Seeded targets have empty aliases. samples/targets.csv aliases were never imported.

| Target                  | Stored | Tool query                | Better query               | Missed / extra                         |
|-------------------------|--------|---------------------------|----------------------------|----------------------------------------|
| Anthropic Claude Code   | 0      | Anthropic Claude Code → 0 | Claude Code → 44           | ~39–44 missed Claude Code CVEs         |
| Chroma                  | 24     | Chroma → 24               | ChromaDB → 7 (all in DB)   | ~17 junk extra                         |
| Home Assistant Green    | 4 ZDI  | Home Assistant Green → 0  | Home Assistant → ~45       | 0 Green-specific; Core is a scope call |
| LiteLLM                 | 30     | LiteLLM → 30              | subset                     | 0                                      |
| NVIDIA Dynamo           | 15     | NVIDIA Dynamo → 15        | —                          | 0                                      |
| OpenAI Codex            | 4      | OpenAI Codex → 3 NVD      | —                          | 0 NVD; +ZDI-26-305 valid               |
| Oracle Autonomous AI DB | 0      | 0                         | Autonomous AI Database → 0 | none published                         |
| Oura Ring 5             | 0      | 0                         | Oura Ring → 0              | none published                         |
| Philips Hue Bridge Pro  | 1      | ...Bridge Pro → 1         | Philips Hue Bridge → 11    | 8× 2026 Hue Bridge (may apply)         |
| Postgres pgvector       | 0      | Postgres pgvector → 0     | pgvector → 6               | 2 real missed + 4 adjacent             |
| Samsung Galaxy S26      | 0      | 0                         | 0                          | none published                         |

### 4.1 Missed — Claude Code (high confidence)

“Anthropic Claude Code” exact = 0. “Claude Code” exact = 44. About 39/44 descriptions start as “Claude Code is an agentic coding tool...”. Examples not in Mongo: CVE-2025-52882, CVE-2025-54794, CVE-2025-54795, CVE-2025-55284, CVE-2025-58764, CVE-2025-59041, CVE-2025-59828, and ~36 more. Root cause: search uses the seeded display name, not alias *claudio code*.

### 4.2 Missed — pgvector (high confidence)

| CVE            | In DB? | Notes                                                  |
|----------------|--------|--------------------------------------------------------|
| CVE-2026-3172  | No     | Buffer overflow in pgvector 0.6.0–0.8.1 — real product |
| CVE-2026-18022 | No     | IVFFlat wraparound, fixed in 0.8.6 — real product      |
| CVE-2024-23751 | No     | LlamaIndex Text-to-SQL — mentions pgvector             |
| CVE-2026-25211 | No     | Llama Stack logs pgvector password                     |
| CVE-2026-55405 | No     | LangChain4j embedding store                            |
| CVE-2026-60090 | No     | PraisonAI PGVector backend                             |

### 4.3 Possible miss — Philips Hue Bridge 2026

Stored: CVE-2026-73669 only (Bridge **Pro** MQTT). “Philips Hue Bridge” also returns CVE-2026-3555 ... CVE-2026-3562 (Zigbee / HomeKit RCE and auth bypass). Those say “Hue Bridge”, not “Bridge Pro”. Not stored. Whether they affect Pro is unconfirmed. Older non-Pro: CVE-2017-14797, CVE-2020-6007.

## 5. Wrong CVEs already stored (Chroma)

All 7 “ChromaDB” NVD hits **are** in the DB. The other ~17 “Chroma” hits are not chroma-core.

| CVE (examples)                                             | Actual product                      |
|------------------------------------------------------------|-------------------------------------|
| CVE-2012-0851, 2013-2277, 2015-8217, 2018-7557, 2026-65706 | FFmpeg / libavcodec “chroma format” |
| CVE-2020-16602, 2021-30493, 2021-30494                     | Razer Chroma SDK / Synapse          |
| CVE-2021-3941                                              | OpenEXR ImfChromaticities           |
| CVE-2023-3739                                              | ChromeOS Chromad                    |
| CVE-2023-54353                                             | Chromacam                           |

Real ChromaDB already stored: CVE-2026-45829...45833, CVE-2026-8828, and borderline CVE-2024-45848 (MindsDB + ChromaDB integration). Stored severity mix of all 78 rows: CRITICAL 8, HIGH 44, MEDIUM 18, LOW 8.

## 6. Incremental NVD sync 404

sync\_all() sets since\_year to the max CVE year already linked. NvdSource then sends pubStartDate=2026-01-01T00:00:00.000 and no pubEndDate. NVD 2.0 requires both (max 120-day window) → HTTP 404.

| Target                                  | NVD since | ZDI since | Effect on next sync_all              |
|-----------------------------------------|-----------|-----------|--------------------------------------|
| Chroma                                  | 2026      | 2025      | NVD 404                              |
| LiteLLM                                 | 2026      | 2025      | NVD 404                              |
| NVIDIA Dynamo                           | 2026      | —         | NVD 404                              |
| OpenAI Codex                            | 2026      | 2026      | NVD 404                              |
| Philips Hue Bridge Pro                  | 2026      | —         | NVD 404                              |
| Home Assistant Green                    | —         | 2026      | NVD full search (0 on official name) |
| Claude / Oracle / Oura / pgvector / S26 | —         | —         | Full search; official name is 0      |

## 7. Recommended fixes (not applied in this audit)

- 1 Import aliases and search them: at least *Claude Code*, *pgvector*, *Philips Hue Bridge*. Re-sync those targets with sync\_one (no since\_year).
- 2 Unlink Chroma junk (FFmpeg / Razer / Chromad / OpenEXR / Chromacam). Prefer ChromaDB or chroma-core.
- 3 Fix NvdSource: when since\_year is set, send pubEndDate and walk 120-day windows.
- 4 Samsung: do not treat the global SMR headline as S26 firmware, or label the checker “Samsung SMR (not model firmware)”.
- 5 Optionally drop empty p2o so the next silent-empty-sync cannot target the wrong DB.

## 8. Method

Mongo collections, indexes, link integrity, and since\_year via SyncVulnerabilitiesService.\_compute\_since\_years.

FirmwareLookupService.lookup for all 11 targets. GitHub /releases/latest or /tags; npm latest for Claude Code and Codex. NVD cves/2.0 with keywordSearch ± keywordExactMatch, paced ~6 s/request. Samsung bulletin HTML: first regex match plus S26 / SM-S9\* presence. NVD totals can move after 2026-08-19.

Companion markdown (same facts): docs/2026-08-19-data-quality-audit.md